

IdentityTrace

Cross-SaaS Identity Attack Detection Platform

Project Blueprint & Technical Reference

Purpose

Build a modern blue-team platform that detects identity compromise by correlating authentication, OAuth, SaaS, developer-platform, privilege, and data-access activity into evidence-backed incidents.

Project type	Security engineering / detection engineering / identity security
Primary audience	SOC analysts, detection engineers, cloud/identity security teams
Primary implementation	Python + FastAPI + PostgreSQL + graph layer + web dashboard
Build strategy	MVP first; add cross-domain correlation and research evaluation incrementally
Version	1.0 - September 9, 2026

Contents

1. Executive Summary
2. Industry Problem & Project Thesis
3. Scope, Goals & Non-Goals
4. Threat Model & Attack Scenarios
5. System Architecture
6. Telemetry & Normalized Data Model
7. Detection & Correlation Design
8. Identity Graph & Incident Model
9. Analyst Experience & API
10. Testing, Evaluation & Research Method
11. Implementation Roadmap
12. Repository & Engineering Standards
13. Security, Ethics & Safe Testing
14. Deliverables & Definition of Done
15. Stretch Goals
16. Reference Detection Examples
17. Industry References

1. Executive Summary

IdentityTrace is an open-source, lab-safe identity detection platform designed to recognize account takeover and trusted-access abuse across identity providers, SaaS applications, developer platforms, and cloud services. Instead of treating authentication events, OAuth grants, privilege changes, repository access, and data downloads as unrelated alerts, IdentityTrace joins them into a single identity-centered incident timeline and attack graph.

Core project thesis

A suspicious login is often weak evidence by itself. A suspicious login followed by unusual OAuth consent, privilege changes, repository enumeration, and rapid data access is a much stronger security story. IdentityTrace should increase confidence by correlating behavior across domains and time.

1.1 What the finished project should demonstrate

- Hands-on identity security and SaaS/cloud telemetry engineering.
- Detection engineering that goes beyond one-event / one-rule alerting.
- Behavioral baselining and temporal correlation with measurable false-positive control.
- Graph-based incident investigation and evidence chaining.
- Practical SOC workflow: triage, investigate, classify, document, and explain.
- Security engineering discipline: schemas, APIs, tests, versioned detections, reproducible attack simulations, and research metrics.

1.2 MVP success in one sentence

Given normalized Entra ID and GitHub-like audit telemetry, the platform can detect at least three identity-compromise attack chains, correlate related events into one incident, explain the evidence, map behavior to MITRE ATT&CK, and measure detection quality against benign activity.

2. Industry Problem & Project Thesis

Modern intrusions increasingly abuse legitimate identities and trusted authentication flows rather than relying only on malware. This matters because traditional alerting often produces isolated signals: a new device, a token grant, a new application, a repository clone, or a burst of file access. IdentityTrace focuses on the relationships between those signals.

Observed industry pressure	Why it matters to this project
Identity dominates cloud/SaaS intrusion paths	Google Cloud reported identity issues were used for initial access in 83% of major cloud/SaaS incidents it analyzed from H2 2025. The project should therefore center the identity as the investigative anchor.
Trusted authentication is being abused	CrowdStrike reported a 15x increase in monthly device-code phishing attempts in 1H 2026 and incidents where compromised SaaS access moved to data theft within minutes. The project must correlate actions quickly after authentication.
Tokens and integrations bypass simple MFA thinking	Mandiant highlighted long-lived OAuth tokens, session cookies, third-party integrations, and SaaS application consent as attack paths. The platform should score token/app behavior, not just password or MFA outcomes.

2.1 Research question

Primary research question

Can cross-domain identity correlation detect account-takeover attack chains with better precision and lower analyst alert volume than isolated authentication rules?

The project should be built so this question can be tested, not merely asserted. Every detection path should produce machine-readable evidence that can be evaluated against labeled benign and attack scenarios.

3. Scope, Goals & Non-Goals

3.1 Primary goals

- Normalize identity, authentication, OAuth, developer-platform, privilege, and data-access events into one schema.
- Build deterministic detections for suspicious identity events.
- Build behavioral baselines for users, devices, applications, and resource access.
- Correlate related events within configurable time windows into attack chains.
- Represent incidents as a graph of identities, sessions, devices, apps, IPs, privileges, resources, and evidence.
- Expose incidents through an analyst-oriented dashboard and API.
- Map incident evidence to MITRE ATT&CK.
- Create a reproducible evaluation harness with attack and benign telemetry.
- Measure precision, recall, false-positive rate, detection latency, and alert-reduction/correlation performance.

3.2 Non-goals for v1

- Building a production replacement for Microsoft Sentinel, Defender XDR, Splunk, or a commercial ITDR platform.
- Ingesting every SaaS vendor on day one. Start with Entra-like identity telemetry plus GitHub-like developer audit data.
- Allowing an LLM to independently decide whether an incident is malicious.
- Executing live attacks against third-party organizations or systems.
- Automating destructive containment actions in the MVP.
- Claiming statistical generalization beyond the lab dataset without evidence.

3.3 Recommended project boundaries

Layer	MVP	Portfolio-grade v1
Identity telemetry	Entra ID sign-in / synthetic equivalent	Entra ID sign-in + audit + OAuth/application events
Developer telemetry	GitHub synthetic/audit fixture	GitHub organization audit / lab events
Cloud/SaaS	Optional synthetic events	One additional source such as Microsoft 365 audit or AWS CloudTrail identity events
Detection	Rules + simple baselines	Rules + baselines + temporal + graph correlation

Layer	MVP	Portfolio-grade v1
UI	Incident list + detail	Timeline, evidence graph, filters, analyst disposition
Evaluation	Scenario pass/fail	Precision/recall/FPR + baseline comparison + latency

4. Threat Model & Attack Scenarios

IdentityTrace assumes the attacker has obtained or abused a legitimate authentication path and attempts to use trusted access to reach SaaS, developer, or cloud resources. The platform is designed to detect the behavioral consequences of identity compromise, including cases where authentication itself appears successful.

4.1 Protected entities

- Human user identities
- Privileged / administrator identities
- Service principals and OAuth applications
- Sessions and access tokens
- Developer accounts and personal access tokens
- SaaS resources, repositories, files, and sensitive data stores
- Identity-provider configuration and role assignments

4.2 Required attack scenarios

Scenario	Adversary story	Key evidence
A1 - Device-code phishing	A user completes a legitimate device-code authentication that is then used from attacker-controlled infrastructure.	New/unfamiliar IP or device; device-code flow; session used rapidly against SaaS or developer resources; unusual resource access.
A2 - Malicious OAuth consent	A compromised or socially engineered user authorizes an application with risky permissions.	New app; unusual publisher/app; high-risk scopes; offline_access; follow-on API activity; resource access.
A3 - Session/token theft	A stolen session cookie or token is reused without a fresh password challenge.	Session reuse from new network/device context; impossible or improbable travel; abrupt behavior change; no expected interactive-auth sequence.
A4 - Developer token compromise	A GitHub-like personal access token is used by an attacker.	Unusual source infrastructure; repository enumeration; access to sensitive/config repos; large clone/download volume; secret-oriented paths.
A5 - Identity privilege escalation	A compromised identity gains or grants elevated permissions.	New role assignment; high privilege; policy/security change; subsequent access to sensitive resources.
A6 - SaaS data theft	A compromised identity uses legitimate APIs or sessions to collect data.	Volume anomaly; unusual resource types; rare API patterns; rapid access after new session/app/token; bulk download/exfil behavior.

5. System Architecture

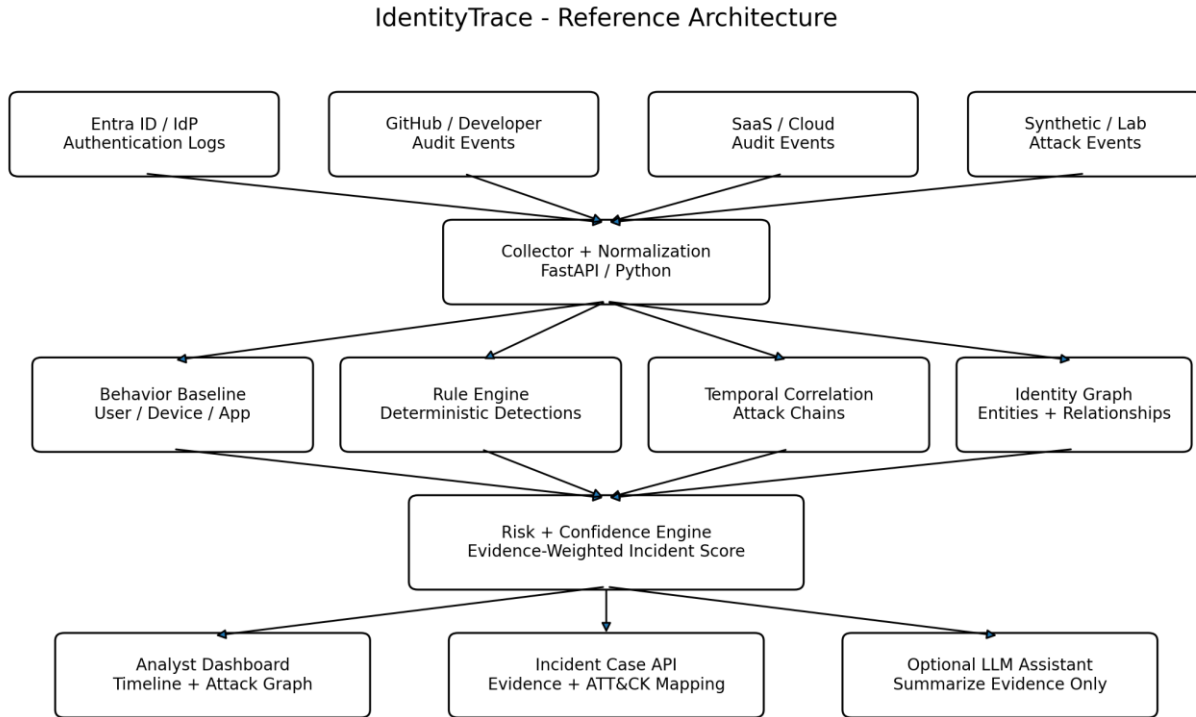


Figure 1. Reference architecture. Detection remains deterministic; optional LLM use is downstream of evidence generation.

5.1 Recommended technology stack

Component	Recommended choice	Reason
API / collector	Python + FastAPI	Strong fit for event ingestion, detection services, testing, and rapid iteration.
Primary database	PostgreSQL	Reliable relational store for normalized events, incidents, rules, dispositions, and metrics.
Graph layer	NetworkX for MVP; Neo4j optional later	NetworkX keeps the MVP lightweight; Neo4j is useful if graph queries become a core feature.
Queue / streaming	None initially; Redis Streams/Kafka optional	Avoid premature complexity. Add only when event throughput requires asynchronous processing.
Frontend	React or lightweight server-rendered UI	Needs incident list, timeline, graph, evidence panel, and disposition workflow.
Containers	Docker Compose	Reproducible local deployment.
Detection definitions	YAML + Python evaluators	Versionable, testable, readable detection logic.
Testing	pytest	Unit, integration, scenario, regression, and false-positive tests.
Optional analyst AI	Local or API LLM behind evidence-only interface	Summarizes already-generated evidence; never becomes the source of truth.

6. Telemetry & Normalized Data Model

6.1 Initial data sources

- Entra ID sign-in events or carefully modeled synthetic equivalents.
- Entra audit / application consent / service-principal / role-assignment events.
- GitHub organization audit events or synthetic fixtures representing token and repository behavior.
- Optional Microsoft 365 / SharePoint / OneDrive audit or AWS CloudTrail identity events for v1 expansion.

6.2 Normalized event schema

Field	Type	Purpose
event_id	UUID	Unique event identifier.
timestamp	UTC datetime	Canonical event time.
source	enum/string	entra, github, m365, aws, synthetic.
event_type	string	Normalized event family.
action	string	login, consent, role_assign, repo_clone, file_download, etc.
result	string	success, failure, blocked, partial.
actor_id	string	Canonical human/service identity key.
actor_type	string	user, service_principal, app, token.
session_id	string/null	Session or correlation identifier.
device_id	string/null	Device or client identifier.
ip_address	inet/string	Source IP.
geo_country	string/null	Derived country/region.
user_agent	string/null	Client / browser / tool.
auth_protocol	string/null	interactive, device_code, oauth, token, PAT, etc.
mfa_result	string/null	success, failure, not_present, not_applicable.
app_id	string/null	OAuth/SaaS app identifier.
permissions	array/json	Requested or granted scopes/roles.
resource_id	string/null	Repository, file, tenant object, API resource.
resource_type	string/null	repo, file, mailbox, role, app, secret, etc.
bytes_transferred	integer/null	Useful for data-access anomalies.
raw_event_ref	string/json	Pointer or copy of source event for analyst evidence.

6.3 Core entities

Entity	Key attributes
--------	----------------

Entity	Key attributes
Identity	id, username, role, privilege tier, department/team, baseline profile
Session	id, identity, auth method, start/end, IP, device, token/app context
Device	id, first_seen, trusted state, OS/user agent, owner
IP / Network	address, ASN, country, reputation metadata, first_seen
OAuth / Service App	app_id, publisher, scopes, consent time, verified/trusted state
Resource	id, type, sensitivity, owner, normal-access cohort
Privilege	role/scope, sensitivity, grant/revoke history
Incident	status, severity, confidence, evidence, entities, ATT&CK mapping, disposition

7. Detection & Correlation Design

IdentityTrace should explicitly separate detection into four layers. This is important for explainability and for research comparison.

Layer	Function	Example
L1 - Atomic rules	Detect individual suspicious events.	New OAuth consent with high-risk scopes.
L2 - Behavioral baseline	Measure deviation from an identity/device/app normal profile.	User accesses repositories never previously seen from a new ASN.
L3 - Temporal correlation	Join suspicious events into a sequence within a time window.	New device -> OAuth grant -> repository enumeration -> bulk clone.
L4 - Graph / contextual correlation	Increase or decrease risk using relationships and asset sensitivity.	The app is new, requests admin-like scope, and accesses a high-value repository.

7.1 Baseline features

- Known devices / user agents
- Common IP ranges / ASNs / countries
- Typical login hours
- Expected authentication protocols
- Frequently used applications
- Normal repositories or SaaS resources
- Typical download/API volume
- Normal privilege level and role changes
- Peer-group comparison where appropriate

7.2 Risk and confidence model

Use a transparent score that analysts can decompose. Avoid a single opaque machine-learning output in the MVP.

```
incident_score = clamp(
    event_risk
```

```

+ behavioral_deviation
+ temporal_chain_bonus
+ asset_sensitivity
+ privilege_context
- benign_context_adjustments,
0, 100
)

confidence = evidence_quality * correlation_strength * telemetry_completeness

```

Design rule

Every point added to risk must have a human-readable reason that appears in the incident evidence panel. A high score without explainable evidence is a design failure.

7.3 Suggested initial scoring bands

Score	Meaning	Expected action
0-29	Low	Store as context; normally no incident.
30-49	Suspicious	Attach to identity timeline; await correlation.
50-69	Medium	Create incident if multiple independent signals exist.
70-84	High	Analyst investigation recommended.
85-100	Critical	Strong correlated evidence of identity compromise or data theft.

8. Identity Graph & Incident Model

8.1 Graph relationships

```

(Identity)-[:AUTHENTICATED_VIA]->(Session)
(Session)-[:FROM]->(IP)
(Session)-[:ON]->(Device)
(Identity)-[:CONSENTED_TO]->(OAuthApp)
(OAuthApp)-[:GRANTED]->(Permission)
(Identity)-[:ACCESSED]->(Resource)
(Identity)-[:ASSIGNED]->(Privilege)
(Event)-[:EVIDENCE_FOR]->(Incident)

```

8.2 Incident object

```

{
  "incident_id": "INC-0042",
  "identity_id": "user-123",
  "severity": "high",
  "score": 82,
  "confidence": 0.91,
  "attack_chain": ["new_session", "oauth_consent", "repo_enum", "bulk_clone"],
  "evidence_ids": ["evt-1", "evt-9", "evt-11", "evt-18"],
  "attack_mapping": ["T1078 Valid Accounts"],
  "status": "open",
  "analyst_disposition": null
}

```

8.3 Correlation windows

Use configurable windows rather than hard-coding every scenario. Examples: 5 minutes for account takeover to data access, 30 minutes for identity + OAuth + privilege chains, and 24 hours for slower persistence or application-consent follow-up. Store the window used in the incident evidence so evaluation is reproducible.

9. Analyst Experience & API

9.1 Minimum dashboard pages

Page	Required content
Overview	Open incidents by severity, recent high-risk identities, source health, detections triggered.
Incident queue	Severity, confidence, identity, first/last event, scenario, status, analyst.
Incident detail	Plain-language summary, timeline, graph, evidence cards, score breakdown, ATT&CK mapping, raw event links.
Identity profile	Baseline, known devices/IPs/apps, recent sessions, prior incidents, unusual behavior.
Detection library	Rule name, version, enabled state, ATT&CK mapping, tests, last triggered.
Evaluation	Scenario results, precision/recall/FPR, alert-reduction, latency, regression history.

9.2 Suggested API endpoints

- POST /events - ingest normalized or source-specific event.
- GET /incidents - filter by severity, identity, status, scenario, date.
- GET /incidents/{id} - incident, evidence, graph, score breakdown.
- PATCH /incidents/{id} - analyst status/disposition/notes.
- GET /identities/{id} - baseline, recent events, sessions, risk.
- GET /detections - detection definitions and versions.
- POST /evaluation/run - execute labeled scenario suite.
- GET /metrics - detection and evaluation metrics.

9.3 Optional LLM analyst assistant

Allowed role

The LLM may summarize an already-created incident, explain detection evidence, produce an analyst-readable case narrative, or suggest investigation questions. It must not create the ground-truth malicious/benign label or secretly change risk scores.

10. Testing, Evaluation & Research Method

10.1 Dataset strategy

- Create a reproducible benign telemetry generator representing normal users, devices, applications, and resource access.
- Create labeled attack scenario generators for A1-A6.

- Use fixed random seeds and checked-in scenario configuration.
- Where real lab telemetry is available, store sanitized fixtures rather than secrets or production identifiers.
- Split evaluation into development fixtures and held-out scenario variations to reduce overfitting to one exact event sequence.

10.1.1 Recommended source mix

The evaluation dataset should combine three complementary sources rather than depend on one pre-built corpus. This gives IdentityTrace realistic background telemetry while preserving exact ground truth for every controlled attack.

Source	Role in the project	Why it matters
Splunk BOTS v3	Public background cloud/security telemetry	Useful for realistic enterprise noise and AWS telemetry without requiring a large local corpus.
Splunk BOTS v2	Optional larger enterprise dataset	Adds Active Directory and Microsoft 365-oriented telemetry when broader background data is needed; use selectively because of its larger size.
Microsoft Entra lab telemetry	Primary identity/authentication ground truth	Generate sign-in, audit, app-consent, identity and privilege events from controlled test identities.
GitHub lab telemetry	Developer/SaaS identity activity	Generate repository, API/token and audit activity for developer-account compromise scenarios.
OCSF schema/examples	Normalization reference	Use as a design reference for consistent event fields across identity, cloud and SaaS sources; OCSF is not itself an attack dataset.
Synthetic scenario generator	Controlled benign and malicious sequences	Creates repeatable labeled events for attack scenarios A1-A6 and tricky benign lookalikes.

10.1.2 Three-layer dataset design

Layer 1 - public background telemetry

Use BOTS telemetry as background activity and event noise. The purpose is not to pretend that BOTS directly represents modern Entra/OAuth attacks; it is to prevent evaluation against unrealistically clean synthetic logs.

Layer 2 - controlled benign activity

- Create 5-10 lab identities with distinct personas, such as normal employee, developer, administrator, security analyst, and service account.
- Generate routine logins, GitHub activity, OAuth use, file access, API calls, password resets, normal admin changes, occasional new devices, travel, and legitimate bulk activity.
- Include benign edge cases that look suspicious in isolation so false-positive behavior can be measured honestly.

Layer 3 - controlled attack sequences

- Inject labeled device-code abuse, malicious OAuth consent, stolen-session behavior, developer-token misuse, privilege escalation, and SaaS/cloud bulk-data access.
- Vary timing, event order, source IP, device familiarity, user role, and data volume so the engine cannot overfit to one exact attack template.
- Keep attack generation isolated to lab-owned accounts and resources. Do not use real third-party identities or production tenants.

10.1.3 Ground-truth labeling

Every event used for evaluation must be traceable to a known benign or malicious scenario. Labels are evaluation metadata, not features exposed to the detector.

```
{
  "event_id": "evt-000042",
  "timestamp": "2026-09-09T14:05:17Z",
  "user": "alice@example.test",
  "source": "entra",
  "event_type": "oauth_consent",
  "src_ip": "203.0.113.25",
  "application": "TestApp",
  "resource": "SharePoint",
  "action": "grant_permission",
  "label": "malicious",
  "attack_id": "A0042",
  "attack_type": "oauth_abuse"
}
```

- Benign events use label=benign and no attack_id.
- Malicious events use label=malicious plus attack_id, attack_type, and scenario start/end metadata.
- Store labels outside the production detection path so the engine cannot accidentally "see" the answer during scoring.
- Use held-out variations for final evaluation; do not tune thresholds solely on the same scenarios used to report results.

10.1.4 Recommended dataset targets

These are planning targets, not success claims. Adjust after the telemetry generators are stable.

Dimension	Initial target
Lab identities	5-10
Benign activity window	7-14 days of generated behavior
Benign events	10,000-50,000+
Attack sequences	100-500 across all attack families
Attack families	6 required scenarios (A1-A6)
Telemetry sources	At least Entra + GitHub for MVP; public BOTS data as background context

10.1.5 Dataset repository layout

```
datasets/
├── public/
│   ├── botsv3/
│   └── botsv2_optional/
├── lab/
│   ├── entra/
│   └── github/
├── generated/
│   ├── benign/
│   ├── attacks/
│   └── mixed/
├── labels/
│   ├── attacks.csv
│   └── event_labels.parquet
└── schemas/
```

```
├── normalized_event.schema.json
└── README.md
```

Do not commit secrets, access tokens, tenant identifiers, real employee data, or unsanitized logs. Large public corpora should be downloaded through documented setup scripts rather than committed directly to Git.

10.1.6 How the dataset proves value

- Precision/recall/F1: compare detector output to ground-truth labels.
- False-positive rate: measure how often benign but unusual behavior is incorrectly escalated.
- Mean time to detect (MTTD): compare scenario start time with first high-confidence incident time.
- Alert compression: compare the number of isolated atomic alerts with the number of correlated incidents presented to an analyst.
- Baseline comparison: run the same mixed dataset through isolated rules and through the full correlation engine.
- Ablation testing: remove one signal family at a time (for example OAuth context or behavioral baseline) to quantify which evidence actually improves detection.

10.1.7 Data acquisition sequence

1. Step 1: Download and inspect BOTS v3; identify which event classes are useful as realistic background telemetry.
2. Step 2: Define the normalized event schema before writing detectors.
3. Step 3: Create Entra and GitHub lab accounts/personas and collect benign telemetry.
4. Step 4: Build reproducible benign event generators for volume and edge cases that are difficult to create manually.
5. Step 5: Implement A1-A6 attack scenario generators in isolated lab resources and capture resulting telemetry.
6. Step 6: Produce a mixed chronological dataset plus separate ground-truth labels.
7. Step 7: Freeze a held-out evaluation split before tuning final thresholds.
8. Step 8: Run baseline and IdentityTrace evaluations and publish metrics plus limitations.

10.2 Baseline comparison

Compare the full correlation engine against a simpler baseline consisting of isolated rules such as new country, new device, risky OAuth scope, or bulk download. The research value comes from showing whether correlation improves signal quality rather than merely adding more rules.

10.3 Required metrics

Metric	Definition	Why it matters
Precision	True positive incidents / all incidents raised	Shows analyst trust and false-positive burden.
Recall	Detected attack scenarios / all attack scenarios	Shows coverage.
False-positive rate	Benign sequences incorrectly raised as incidents	Directly measures alert noise.
Detection latency	Time from first malicious event to incident creation	Measures whether correlation is timely enough.
Alert reduction	Atomic suspicious events consolidated into correlated incidents	Shows SOC workload reduction.

Metric	Definition	Why it matters
Scenario coverage	Attack scenarios with at least one successful detection path	Shows breadth.
Evidence completeness	Incidents containing sufficient source evidence and explanations	Measures investigation usability.

10.4 Test pyramid

- Unit tests: normalizers, feature calculations, scoring, rule predicates.
- Detection tests: one positive and multiple negative cases for every rule.
- Correlation tests: correct ordering, window boundaries, duplicate events, missing telemetry.
- Integration tests: ingest -> normalize -> detect -> correlate -> incident API.
- Regression tests: previously fixed false positives remain fixed.
- Adversarial tests: reorder events, slow down attack chain, use known device with unusual token, split activity across sources.

11. Implementation Roadmap

Phase	Build focus	Exit criterion
Phase 0 - Specification	Freeze schemas, threat scenarios, repository structure, definition of done.	Architecture doc + scenario catalog + event schema.
Phase 1 - Event pipeline	FastAPI ingestion, validation, normalization, PostgreSQL persistence.	Events can be ingested, queried, replayed, and traced to raw evidence.
Phase 2 - Atomic detections	Implement versioned deterministic rules and test harness.	At least 8-12 atomic detections with positive/negative tests.
Phase 3 - Behavioral baselines	Track known devices, IP/ASN, app/resource use, volume, login time.	Identity profile exposes baseline and deviations.
Phase 4 - Temporal correlation	Build scenario-agnostic sequence correlation and incident creation.	A1-A3 generate one correlated incident rather than disconnected alerts.
Phase 5 - Identity graph	Create entity relationships and graph view.	Incident detail visualizes causal/evidence relationships.
Phase 6 - Cross-domain expansion	Add GitHub/developer and one SaaS/cloud data source.	A4-A6 supported with normalized telemetry.
Phase 7 - Evaluation	Build benign/attack scenario suite and compare with isolated-rule baseline.	Metrics report with precision, recall, FPR, latency, alert reduction.
Phase 8 - Portfolio hardening	Docs, Docker, screenshots, demo dataset, threat-model write-up, CI.	Another engineer can clone, run, reproduce attacks, and verify results.

11.1 MVP cut line

Stop and demo here if needed

Phases 0-4 are enough for a legitimate MVP: normalized identity telemetry, tested atomic detections, baselines, and correlated incidents for at least three identity-compromise scenarios. Everything after that improves breadth, visualization, and research rigor.

12. Repository & Engineering Standards

12.1 Suggested repository layout

```
identitytrace/
├── app/
│   ├── api/
│   ├── collectors/
│   ├── normalizers/
│   ├── detections/
│   ├── correlation/
│   ├── baselines/
│   ├── graph/
│   ├── incidents/
│   └── models/
├── detections/
│   ├── entra/
│   ├── github/
│   └── cross_domain/
├── scenarios/
│   ├── benign/
│   └── attacks/
├── tests/
│   ├── unit/
│   ├── detection/
│   ├── correlation/
│   └── integration/
├── dashboard/
├── docs/
│   ├── architecture.md
│   ├── threat-model.md
│   ├── detections.md
│   └── evaluation.md
├── docker-compose.yml
├── pyproject.toml
└── README.md
```

12.2 Detection-as-code conventions

- Every detection has an ID, title, description, severity, ATT&CK mapping, required fields, logic, version, and tests.
- Every correlation rule documents its sequence, time window, required/optional evidence, and suppression logic.
- False-positive exceptions must be narrow, documented, and regression-tested.
- Rule changes should be reviewed through Git and CI; no undocumented logic changes in the UI.
- Include a changelog for important detection behavior changes.

12.3 Suggested CI checks

- Python formatting/linting
- Unit tests
- Detection fixture tests
- Schema validation for detection YAML
- Migration checks
- Docker build
- Scenario smoke test
- Coverage threshold for core detection/correlation modules

13. Security, Ethics & Safe Testing

- Use only accounts, tenants, repositories, and systems you own or are explicitly authorized to test.
- Prefer synthetic fixtures or dedicated lab tenants for attack simulation.
- Never publish live credentials, access tokens, session cookies, client secrets, tenant identifiers, or sensitive user data.
- Redact IPs/usernames in public screenshots unless they are synthetic or intentionally public attack infrastructure collected lawfully.
- Store secrets in environment variables or a local secret manager; never commit them.
- Keep attack modules focused on generating telemetry, not on stealth, persistence, or unauthorized access.
- Document the ethical boundary in the README so reviewers understand the system is a defensive research platform.

14. Deliverables & Definition of Done

14.1 Required repository deliverables

- Public README with problem statement, architecture, quick start, screenshots, and measurable results.
- Architecture diagram and data-flow explanation.
- Threat model and attack scenario catalog.
- Normalized event schema documentation.
- Detection library documentation with ATT&CK mappings.
- Reproducible benign and attack scenario fixtures.
- Docker Compose deployment.
- Automated tests and CI.
- Evaluation report comparing isolated rules vs cross-domain correlation.
- Two or more polished incident case studies showing the full investigation flow.
- Short demo video or GIF demonstrating ingestion -> detection -> correlated incident -> analyst investigation.

14.2 Portfolio-grade definition of done

Dimension	Completion criterion
Functional	A1-A6 can be reproduced or replayed with documented setup.
Detection quality	Metrics are reported honestly, including false positives and misses.
Explainability	Every incident displays the events and reasons that produced the score.

Dimension	Completion criterion
SOC usability	Analyst can move from incident queue to timeline/graph/evidence and record disposition.
Engineering	Project starts from clean clone using documented commands.
Testing	Core detection/correlation logic has automated positive/negative/regression tests.
Security	No credentials or sensitive tenant data are embedded in repository artifacts.
Documentation	A reviewer can understand architecture and reproduce at least one scenario without private guidance.

15. Stretch Goals

- Add Microsoft 365 / SharePoint data-access correlation.
- Add AWS CloudTrail identity events or Google Workspace audit as a third domain.
- Use Neo4j for richer graph queries and attack-path analysis.
- Add IP/ASN enrichment and known anonymizer/hosting-provider context.
- Add peer-group baselines for users with similar roles.
- Add risk decay so stale signals lose weight over time.
- Add analyst feedback loop that records false-positive reasons and recommends narrowly scoped tuning candidates.
- Add case export in Markdown/PDF for interview/demo artifacts.
- Add optional evidence-grounded LLM case summary with citations to event IDs.
- Package the project as an OpenTelemetry-like ingestion adapter framework for easier new-source support.

16. Reference Detection Examples

16.1 Atomic detection - risky OAuth consent

```

id: IDT-OAUTH-001
title: Risky OAuth consent
severity: medium
source: entra
required_fields: [actor_id, app_id, permissions, timestamp]
match:
  any_permission:
    - offline_access
    - Files.Read.All
    - Mail.Read
conditions:
  app_first_seen_for_user: true
  publisher_trusted: false
score: 35
attack: ["Valid Accounts", "Additional Cloud Roles / Cloud Permissions"]

```

16.2 Correlation - identity takeover to data access

```

id: IDT-CORR-004
title: New session -> risky app consent -> sensitive data access
window: 15m
identity_key: actor_id
sequence:
  - event: new_session_context

```

```

- event: risky_oauth_consent
- event: sensitive_resource_access
required_count: 3
score_bonus: 40
create_incident: true

```

16.3 Example incident evidence narrative

INC-0042 | HIGH | Score 82 | Confidence 0.91

```

17:02:11 User authenticated through a device-code flow.
17:02:19 Session originated from an ASN not previously observed for the user.
17:04:02 New OAuth application received offline_access and Files.Read.All.
17:06:40 Application enumerated sensitive resources.
17:08:15 Download volume exceeded the user's established baseline.

```

Reason for incident: Five related signals occurred for the same identity within six minutes, spanning authentication, application consent, and data access.

Analyst action: Validate device-code request with user, review app consent, revoke token/app grant if unauthorized, inspect resources accessed, and preserve evidence.

17. Industry References

These references justify the project problem statement and can be cited in the README or research report. They are not implementation requirements.

Google Cloud - Cloud Threat Horizons Report H1 2026

<https://cloud.google.com/security/report/resources/cloud-threat-horizons-report-h1-2026>

Identity issues used for initial access in 83% of major cloud/SaaS incidents analyzed from H2 2025; data targeted in 73% of cloud-related incidents.

CrowdStrike - 2026 Threat Hunting Report

<https://www.crowdstrike.com/en-us/resources/reports/threat-hunting-report/>

Reports trusted authentication as an attack path, a 15x spike in monthly device-code phishing attempts in 1H 2026, and rapid SaaS/cloud abuse.

Google Cloud / Mandiant - M-Trends 2026 Executive Edition

<https://cloud.google.com/security/resources/m-trends-executive-edition>

Highlights long-lived OAuth tokens, session cookies, third-party SaaS integrations, and application consent as identity/security risks.

- Splunk Boss of the SOC (BOTS) v3 repository: <https://github.com/splunk/botsv3>
- Splunk Boss of the SOC (BOTS) v2 repository: <https://github.com/splunk/botsv2>
- Open Cybersecurity Schema Framework (OCSF) schema: <https://github.com/ocsf/ocsf-schema>
- Microsoft documentation for Entra ID / Sentinel identity log integration: <https://learn.microsoft.com/en-us/azure/sentinel/connect-azure-active-directory>

Blueprint Usage Notes

How to use this document

Treat Sections 3-10 as the technical contract, Section 11 as the build sequence, Section 14 as the release gate, and Section 16 as starter logic rather than final production rules. Update this blueprint whenever the schema, threat model, or evaluation method materially changes.